

Avaliação de vulnerabilidades e identificação de riscos

A proteção dos ativos de informação tornou-se uma preocupação estratégica nas organizações modernas. Com o crescimento da digitalização dos processos e o aumento das ameaças cibernéticas, identificar riscos e vulnerabilidades em ambientes de TI passou a ser um pré-requisito importante para a manutenção da integridade, disponibilidade e confidencialidade dos dados. Nesse contexto, a avaliação sistemática de riscos desponta como uma exigência normativa e uma prática vital para a resiliência organizacional.

Este capítulo tem como objetivo apresentar os principais conceitos, métodos e ferramentas relacionados à identificação e à análise de vulnerabilidades em ambientes tecnológicos. Parte-se da compreensão acerca da importância de mapear fragilidades físicas e lógicas, reconhecendo que uma vulnerabilidade, ao ser explorada, pode resultar em impactos significativos à operação da empresa.

Serão discutidas as técnicas de avaliação de riscos, abordando metodologias qualitativas e quantitativas, bem como a priorização desses riscos com base em critérios de impacto e probabilidade. Também serão analisadas ferramentas amplamente utilizadas para apoiar o processo de diagnóstico, como scanners de vulnerabilidades e frameworks normativos, como a ISO/IEC 27005 e o Nist (2012).

O capítulo também aborda a importância da implementação de políticas de gestão de riscos alinhadas à realidade da organização, com foco na mitigação proativa de ameaças e na construção de um ambiente seguro e controlado. A estruturação dessas políticas contribui diretamente para decisões mais assertivas sobre investimentos em segurança e para o cumprimento de requisitos legais e regulatórios.

Ao final deste capítulo, espera-se que o leitor tenha desenvolvido um olhar analítico e preventivo diante dos riscos que envolvem os sistemas de informação. Além disso, saiba mapear vulnerabilidades e definir estratégias de resposta que garantam a continuidade do negócio em um cenário de ameaças, as quais que têm se tornado cada vez mais sofisticadas e persistentes.

1 A importância da identificação de riscos e vulnerabilidades em ambientes de TI

Ambientes de TI estão cada vez mais expostos a ameaças que comprometem ativos críticos das organizações, como dados, sistemas e processos operacionais. Essa exposição decorre tanto da complexidade

crescente das infraestruturas tecnológicas quanto da presença de vulnerabilidades que, uma vez exploradas, podem causar prejuízos significativos à continuidade dos negócios (Machado, 2014).

Identificar essas fragilidades é parte estratégica da gestão da segurança da informação, pois permite conhecer os pontos “fracos” de sistemas, redes, dispositivos e processos. Barreto *et al.* (2018) destacam que, ao negligenciar medidas básicas de segurança (como controle de acesso, gestão de senhas e proteção física) a organização se torna mais suscetível a ataques, fraudes, sabotagens ou mesmo falhas acidentais. O desconhecimento desses riscos amplia a chance de danos à integridade, disponibilidade e confidencialidade da informação.

Além das ameaças intencionais, como invasões e roubo de dados, os riscos envolvem eventos naturais e ações involuntárias de usuários, como erros operacionais e falhas de configuração. Assim, a análise deve considerar todo o ecossistema da informação: da infraestrutura física e lógica até os aspectos humanos e organizacionais (Barreto *et al.*, 2018).

Konopczyk (2022) aponta que uma abordagem eficaz começa com a identificação dos ativos da informação e das ameaças às quais estão expostos. A partir disso, é possível mapear vulnerabilidades e estimar a probabilidade de incidentes, o que contribui para definir as prioridades e ações de resposta adequadas. Ignorar essa etapa compromete a capacidade da empresa de reagir com agilidade diante de falhas ou ataques.

Ao reconhecer e classificar os riscos, as organizações podem tomar decisões mais seguras sobre investimentos, medidas de proteção e políticas de prevenção. Essa prática também contribui para a aderência a normas, como a ISO/IEC 27005, que orienta a gestão de riscos de segurança da informação a partir de uma estrutura sistemática e integrada (Pegetti, 2022).



IMPORTANTE

A identificação de riscos e vulnerabilidades (como um processo contínuo, revisado e atualizado) reduz impactos operacionais e protege a reputação institucional.

1.1 Análise de vulnerabilidades em ambientes de TI

Ambientes de TI estão sujeitos a falhas que podem comprometer a segurança das informações e a continuidade dos serviços. Essas fragilidades, conhecidas como vulnerabilidades, correspondem a brechas em sistemas, dispositivos ou processos que, se exploradas, podem permitir acessos indevidos, interrupções ou perdas de dados. Compreender onde elas estão e como podem ser exploradas é um passo necessário para proteger os ativos da organização (Konopczyk, 2022).

De acordo com Machado (2014), uma vulnerabilidade pode estar presente em softwares, hardwares ou procedimentos mal-definidos. Ela representa uma oportunidade de ataque, funcionando como uma “porta aberta” para que uma ameaça tenha êxito. Barreto *et al.* (2018) ilustram esse conceito com a analogia de uma porta destrancada: não garante uma invasão, mas a facilita. Em TI, isso se aplica, por exemplo, à ausência de controle sobre senhas, configurações incorretas de sistemas ou até mesmo a falta de proteção física em salas de servidores.

As vulnerabilidades podem estar distribuídas em diversas camadas da infraestrutura: ambiente físico, dispositivos de hardware, aplicações, redes de comunicação e até mesmo na conduta dos usuários. Barreto *et al.* (2018) apontam que falhas estruturais, como variações de energia, sistemas sem autenticação adequada ou ausência de backup, representam riscos consideráveis se não forem devidamente mapeadas e tratadas.

O processo de análise de vulnerabilidades envolve ações como a identificação dos ativos, a avaliação dos pontos fracos e a produção de relatórios que orientam decisões técnicas e estratégicas. Esse trabalho depende tanto de ferramentas automatizadas quanto da atuação de profissionais capacitados, sendo um processo contínuo e preventivo, voltado à minimização de riscos e à preservação da integridade dos sistemas (Konopczyk, 2022; Barreto *et al.*, 2018).

A análise de vulnerabilidades deve ser compreendida como uma atividade que apoia a gestão de riscos, fornecendo visibilidade sobre os fatores que tornam a organização mais exposta. Isso permite não só reagir a incidentes, mas agir de forma antecipada, fortalecendo a resiliência da infraestrutura de TI.

1.1.1 Ferramentas para análise de vulnerabilidades

A detecção de vulnerabilidades exige o uso de ferramentas específicas que auxiliam na identificação de brechas nos sistemas, dispositivos e redes da organização. Essas soluções automatizadas são fundamentais para realizar varreduras periódicas, simular ataques e gerar relatórios que indicam as falhas exploráveis nos ativos tecnológicos (Konopczyk, 2022).

Dentre as ferramentas mais utilizadas estão os scanners de vulnerabilidades, que realizam inspeções em sistemas operacionais, aplicações, bancos de dados e dispositivos de rede, procurando por configurações incorretas, atualizações ausentes ou serviços expostos. Esses scanners são classificados em diferentes categorias, entre as quais se destacam os baseados em assinatura — que comparam as vulnerabilidades identificadas com um banco de dados conhecido, e os comportamentais — que detectam anomalias de funcionamento.

A escolha da ferramenta deve considerar o porte da organização, o tipo de ambiente analisado e os objetivos da avaliação. Ferramentas

como Nessus, OpenVAS, Qualys e Nikto, por exemplo, oferecem funcionalidades que permitem o monitoramento contínuo de ambientes heterogêneos. Algumas soluções também contam com interfaces que facilitam a visualização dos riscos, priorização das correções e integração com sistemas de gestão de segurança da informação.

Konopczyk (2022) reforça que o uso dessas ferramentas deve estar inserido em um processo estruturado de gestão de vulnerabilidades, em que as informações coletadas sejam devidamente analisadas e transformadas em ações concretas. O simples uso de scanners não garante proteção; é necessário interpretar os dados, definir prioridades e aplicar contramedidas eficazes.

Vale destacar que as ferramentas não substituem a atuação humana. Elas são aliadas dos profissionais de TI, que precisam ter capacidade crítica para interpretar os relatórios, verificar falsos positivos e alinhar as descobertas às políticas da organização. O uso combinado de tecnologia, conhecimento técnico e processos bem-definidos é o que assegura uma análise de vulnerabilidades eficaz e contínua.

1.1.2 Identificação de fraquezas em infraestrutura física e lógica

A identificação de fraquezas em ambientes de TI requer uma abordagem abrangente, que considere tanto os aspectos físicos quanto os lógicos da infraestrutura. Isso porque as vulnerabilidades podem surgir em diferentes camadas, abrangendo desde falhas estruturais e ambientais até erros de configuração de sistemas ou permissões inadequadas de acesso (Barreto *et al.*, 2018).

No nível físico, estão os riscos relacionados à localização e à proteção dos equipamentos. Claros exemplos são salas de servidores desprotegidas, suscetíveis a acessos não autorizados, incêndios ou variações de energia. A ausência de controles de climatização, alarmes, nobreaks

ou câmeras de vigilância pode comprometer a disponibilidade dos serviços e a integridade dos dados.

Já no nível lógico, as fraquezas são mais associadas à configuração de sistemas, aplicações e redes. É o caso de servidores com atualizações de segurança pendentes, uso de senhas fracas, ausência de autenticação multifator e falhas em políticas de backup. Segundo Machado (2014), práticas como reutilização de credenciais, contas com privilégios excessivos e ausência de registros de auditoria abrem caminhos para invasões e vazamento de dados.

A avaliação desses pontos deve considerar os processos internos, os sistemas interconectados e os usuários que operam os recursos tecnológicos. Barreto *et al.* (2018) ressaltam que falhas humanas, como o uso indevido de mídias removíveis ou a instalação de softwares não autorizados, também devem ser consideradas no diagnóstico de fraquezas.

Konopczyk (2022) enfatiza que identificar essas vulnerabilidades não significa apenas encontrá-las, mas compreender seu impacto potencial no ambiente organizacional. Por exemplo, uma simples falha na gestão de senhas pode permitir o acesso indevido a sistemas sensíveis, resultando em roubo de informações ou interrupção de serviços essenciais.

Portanto, o mapeamento das fragilidades deve ser contínuo, preventivo e integrado à cultura de segurança da informação da empresa, com foco na mitigação de riscos, evitando que vulnerabilidades identificadas se transformem em incidentes.

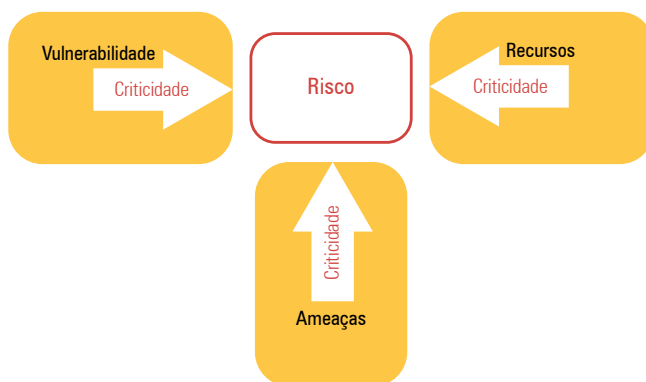
2 Técnicas de avaliação e priorização de riscos

Após a identificação das vulnerabilidades e ameaças, é necessário avaliá-las e organizá-las conforme sua criticidade. Isso permite que os riscos mais relevantes sejam tratados com prioridade, otimizando

recursos e protegendo os ativos mais sensíveis da organização. Essa etapa envolve o uso de metodologias de avaliação e ferramentas que auxiliam na classificação e decisão sobre os riscos (Konopczyk, 2022).

A figura 1 apresenta a relação entre ameaças, vulnerabilidades, riscos e recursos.

Figura 1 – Relação entre ameaças, vulnerabilidades, riscos e recursos



Fonte: Machado (2014, p. 53).

Avaliar um risco consiste, essencialmente, em estimar duas variáveis principais: a probabilidade de um incidente ocorrer e o impacto que ele causaria à organização. Combinando essas informações, é possível determinar o nível de risco. Essa análise pode ser feita por meio de abordagens qualitativas, quantitativas ou mistas, conforme discutido a seguir.

No modelo qualitativo, utiliza-se uma escala subjetiva (com os níveis “baixo”, “médio” e “alto”, por exemplo) para avaliar o impacto e a probabilidade de forma mais prática e rápida. Já o modelo quantitativo atribui valores numéricos, permitindo cálculos mais precisos. Para Konopczyk (2022), a escolha entre as abordagens depende da maturidade da organização e da criticidade dos ativos envolvidos.

Outro elemento importante da priorização é a matriz de riscos, que organiza os riscos em níveis (baixo, médio e alto) cruzando as variáveis de impacto e probabilidade. Essa matriz é usada para ranquear os riscos e guiar a alocação de recursos e esforços de mitigação (Pegetti, 2022).

Por exemplo, ao avaliar dois riscos distintos (um ataque de phishing e uma falha no sistema de backup) a organização pode classificar o primeiro com probabilidade “alta” e impacto “médio”, enquanto o segundo teria probabilidade “baixa” e impacto “alto”. Ao inserir essas classificações na matriz de riscos, o ataque de phishing ficaria posicionado em uma zona de atenção imediata, enquanto a falha no backup, apesar da baixa probabilidade, também receberia prioridade elevada devido ao impacto potencial. Esse mapeamento facilita a visualização e direciona os esforços para os riscos mais críticos.

Além disso, frameworks como ISO/IEC 27005 e o modelo do Nist oferecem diretrizes para esse processo. Esses referenciais incluem critérios para análise e aceitação de riscos, facilitando a padronização das ações e a conformidade com normas e auditorias (Konopczyk, 2022).

O modelo do Nist (2012), especialmente descrito no Nist Special Publication 800-30 Revision 1, apresenta um guia detalhado para a condução de avaliações de riscos em sistemas de informação. Sua abordagem é dividida em etapas que incluem a preparação, a condução da avaliação (identificação de ameaças, vulnerabilidades, probabilidade e impacto), a comunicação dos resultados e o monitoramento contínuo. Esse framework destaca a importância de considerar fatores organizacionais, tecnológicos e ambientais na análise, proporcionando um método estruturado que pode ser adaptado a diferentes contextos e níveis de maturidade em segurança da informação (Nist, 2012).

2.1 Metodologias qualitativas e quantitativas de avaliação

A análise de riscos, como mencionamos, pode ser conduzida por meio de metodologias qualitativas ou quantitativas, cada uma com suas vantagens e aplicações específicas. A escolha entre elas depende do contexto da organização, do tipo de risco avaliado e da disponibilidade de informações confiáveis para a análise (Konopczyk, 2022).

Na abordagem qualitativa, a avaliação do risco é feita com base em julgamentos subjetivos, geralmente utilizando escalas descritivas como “baixo”, “médio” ou “alto” para classificar tanto a probabilidade quanto o impacto. Essa metodologia é mais simples, rápida e eficaz em contextos nos quais não há dados estatísticos precisos ou quando se busca uma avaliação inicial. De acordo com Konopczyk (2022), essa abordagem permite que profissionais de diferentes áreas participem da avaliação, mesmo sem conhecimento técnico profundo.

Já a abordagem quantitativa atribui valores numéricos às variáveis de risco, permitindo cálculos mais detalhados e objetivos. A análise considera dados históricos, indicadores financeiros ou métricas de segurança para estimar com maior precisão a chance de ocorrência de um evento e seus efeitos. Essa metodologia é útil, por exemplo, quando se precisa estimar o custo potencial de uma falha de segurança ou justificar investimentos em controles preventivos.

Konopczyk (2022) exemplifica o uso da metodologia quantitativa com o seguinte caso: considerando o ativo “notebook”, a ameaça “roubo” e a vulnerabilidade “usuário não sabe como proteger o equipamento”, é possível atribuir valores para impacto e probabilidade (por exemplo, 3 e 4 em uma escala de 0 a 4). O resultado é um risco de nível elevado, o que justifica ações imediatas.

Além disso, existe a análise híbrida ou semiquantitativa, que combina elementos das duas abordagens, oferecendo mais flexibilidade. Ela permite utilizar escalas numéricas para representar classificações subjetivas, como 1 (baixo), 2 (médio) e 3 (alto), proporcionando um meio-termo entre precisão e praticidade.

Independentemente da metodologia escolhida, o mais importante é garantir que ela seja aplicada de maneira coerente com os objetivos da organização, e que permita comparar os riscos entre si para facilitar a tomada de decisão.

2.1.1 Classificação de riscos por impacto e probabilidade

Após identificar os riscos existentes em um ambiente de TI, torna-se necessário classificá-los de acordo com dois critérios principais: impacto e probabilidade. Essa classificação permite compreender a gravidade de cada risco e direcionar os esforços de mitigação de forma proporcional à sua relevância (Konopczyk, 2022).

O impacto se refere às consequências negativas que um risco pode causar à organização caso se concretize. Pode envolver perdas financeiras, interrupção de serviços, danos à reputação, compromissos legais, entre outros. Já a probabilidade está relacionada à chance de ocorrência do evento de risco, considerando o histórico, a vulnerabilidade dos sistemas e a presença de ameaças conhecidas.

Para facilitar esse processo, as organizações costumam utilizar escalas de classificação, que podem ser numéricas (como 0 a 4 ou 1 a 10) ou categóricas (como “baixo”, “médio” e “alto”). A combinação entre impacto e probabilidade resulta em uma matriz de riscos que orienta a priorização das ações.

Por exemplo, um servidor que armazena dados sensíveis, localizado em uma sala sem controle de acesso físico, pode representar um risco

com alto impacto (vazamento de informações) e alta probabilidade (vulnerabilidade física evidente), sendo classificado como risco crítico. Já uma falha em um sistema secundário, com pouco uso e poucos dados envolvidos, pode ser classificada como baixo impacto e baixa probabilidade, merecendo menos atenção imediata.

De acordo com Pegetti (2022), a classificação por impacto e probabilidade é uma etapa essencial para organizar os riscos de acordo com seu nível de criticidade e definir estratégias apropriadas de tratamento, como mitigação, aceitação, transferência ou eliminação.

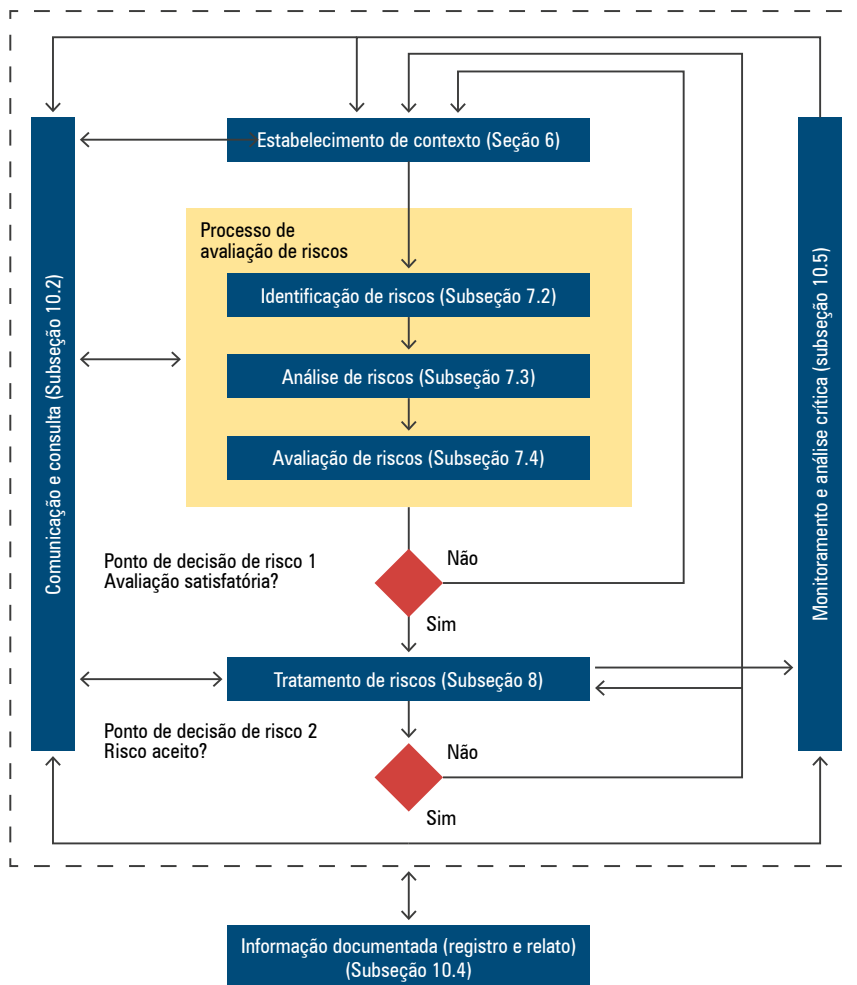
Essa análise precisa ser revisada periodicamente, pois os níveis de risco podem mudar conforme a infraestrutura evolui, novas ameaças surgem ou medidas de segurança são implementadas.

2.1.2 Ferramentas de priorização e frameworks aplicáveis

Após a classificação dos riscos por impacto e probabilidade, o próximo passo envolve a priorização das ações de resposta. Para isso, organizações utilizam ferramentas e frameworks que facilitam a análise, o ordenamento e o tratamento dos riscos de maneira estruturada e eficiente.

O tratamento do risco pode ser visto na figura 2, trazido pela norma ABNT NBR ISO/IEC 27005:2022 (ABNT, 2022).

Figura 2 – Tratamento do risco



Fonte: adaptado de ABNT (2022, p. 5).

Com base nos princípios da norma ABNT NBR ISO/IEC 27005:2002, a gestão de riscos de segurança da informação é conduzida por meio de um ciclo estruturado que integra abordagem sistemática e melhoria contínua. O processo inicia-se pelo estabelecimento do contexto, no qual são definidos o escopo da análise, os ativos a serem protegidos, as partes

interessadas e os critérios de avaliação e aceitação de riscos. Em seguida, realiza-se a avaliação de riscos, composta pela identificação de ameaças e vulnerabilidades, análise da probabilidade e do impacto, e posterior avaliação conforme critérios organizacionais (ABNT, 2022).

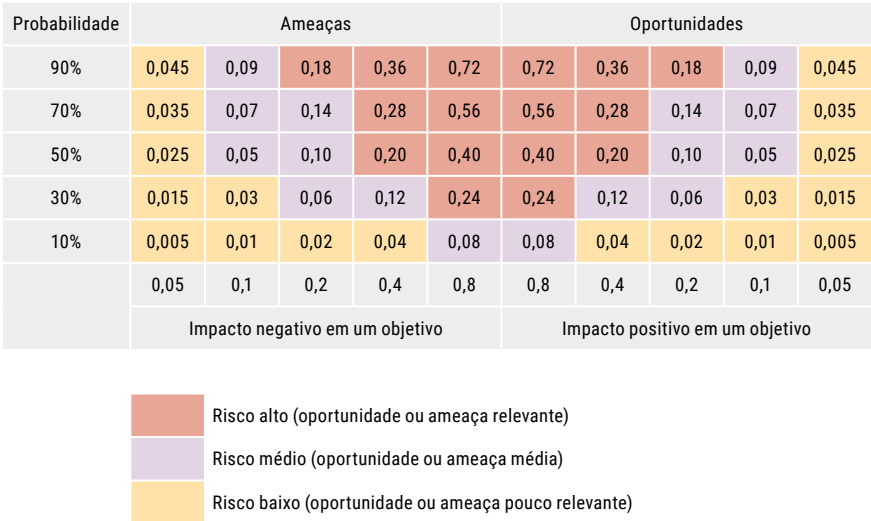
A etapa seguinte envolve o tratamento dos riscos, no qual se selecionam estratégias adequadas (como mitigação, transferência, aceitação ou evitação) de acordo com o nível de risco e as políticas internas. Paralelamente, a comunicação e a consulta asseguram que as informações sobre riscos sejam disseminadas entre as partes interessadas, promovendo alinhamento e entendimento nas decisões (ABNT, 2022).

Por fim, o monitoramento e a revisão acompanham continuamente os riscos, as medidas adotadas e as mudanças no contexto, permitindo ajustes e garantindo a eficácia do processo. Essa dinâmica é cíclica e reflete a lógica do PDCA (plan, do, check, act), recomendada pelas normas ISO para assegurar feedback e melhoria contínua na gestão de riscos (ABNT, 2022).

Partindo agora para as ferramentas, podemos dizer que umas das mais utilizadas é a matriz de risco, que cruza impacto e probabilidade. Ela gera uma visualização gráfica dos riscos com níveis que vão de aceitável a inaceitável. Isso permite aos gestores priorizarem rapidamente os riscos mais críticos. De acordo com Konopczyk (2022), essa abordagem simplifica a tomada de decisão ao destacar quais ameaças exigem respostas imediatas e quais podem ser monitoradas com menor urgência.

A figura 3 apresenta uma matriz de probabilidade, com a descrição dos tipos de riscos.

Figura 3 – Matriz probabilidade x impacto



Fonte: Lima (2009, p. 66).

Além da matriz, ferramentas automatizadas, como o CVSS (common vulnerability scoring system), auxiliam na atribuição de pontuações às vulnerabilidades técnicas, permitindo que se meça sua severidade em escala padronizada. Sistemas de detecção e varredura como Nessus ou OpenVAS também integram relatórios com indicadores úteis para o ranqueamento de riscos.

No campo dos frameworks, destacam-se especialmente:

- ISO/IEC 27005, que fornece diretrizes para o processo completo de gestão de riscos de segurança da informação, com foco na identificação, avaliação, tratamento, comunicação e monitoramento.
- NIST SP 800-30, que propõe um guia técnico detalhado para avaliação de riscos, incluindo definições, métodos e critérios para mensuração e priorização.

- COBIT 5 for Risk, voltado à governança de TI, e que contribui com uma visão integrada da gestão de riscos alinhada aos objetivos do negócio.

Esses frameworks servem como base metodológica para que as organizações adotem práticas consistentes e auditáveis, promovendo a conformidade com exigências legais e a melhoria contínua da segurança da informação.

A aplicação de ferramentas e metodologias apropriadas possibilita uma priorização mais precisa, alocando recursos de forma inteligente e elevando a resiliência do ambiente de TI diante de ameaças constantes.

3 Estabelecimento de políticas de gestão de riscos

A gestão eficaz de riscos em ambientes de TI depende não apenas da identificação e da avaliação dos riscos, mas também da formulação de políticas organizacionais que orientem a prevenção, o monitoramento e a resposta a incidentes. Essas políticas devem refletir o compromisso da organização com a segurança da informação e estabelecer diretrizes claras sobre responsabilidades, controles e procedimentos.

De acordo com Konopczyk (2022), a política de gestão de riscos atua como um documento estruturador, que define os critérios de aceitação de riscos, os níveis de exposição toleráveis e os métodos a serem utilizados na mitigação. Além disso, ela deve indicar os papéis de cada setor da organização, incluindo a alta gestão, os times técnicos e os usuários.

Essas políticas não devem ser genéricas: precisam considerar as características específicas da organização, como seu porte, setor de atuação, nível de maturidade em segurança da informação e obrigações legais e regulatórias. Barreto *et al.* (2018) destacam que normas bem-definidas são decisivas para prevenir falhas humanas, erros operacionais e

condutas negligentes (fatores frequentemente associados à exploração de vulnerabilidades).

Um exemplo prático é a definição de políticas sobre o uso de senhas: ao estabelecer diretrizes sobre complexidade, prazo de expiração e tentativa de acesso, a organização reduz a superfície de ataque e promove uma cultura de responsabilidade entre os usuários.

Além disso, a política de riscos deve prever processos de revisão periódica, integrando-se a outras políticas da organização, como a de backup, controle de acessos e continuidade de negócios. A adoção de frameworks como a ISO/IEC 27005 e o Cobit contribui para que essa política esteja alinhada às boas práticas internacionais e facilite auditorias internas ou externas (Pegetti, 2022).

Por fim, a eficácia dessas políticas depende também de comunicação clara e capacitação contínua dos colaboradores. Um documento bem-elaborado, mas desconhecido pelas equipes, perde sua utilidade prática. Por isso, o estabelecimento da política de gestão de riscos deve estar acompanhado de ações educativas, como treinamentos e campanhas de conscientização.

Considerações finais

Neste capítulo, foram explorados os fundamentos e as práticas relacionadas à identificação de riscos e à análise de vulnerabilidades em ambientes de TI. Constatou-se que compreender as fragilidades (sejam elas físicas, lógicas ou procedimentais) é uma etapa indispensável para proteger os ativos de informação e manter a resiliência organizacional diante de ameaças cada vez mais sofisticadas.

Discutimos que vulnerabilidades representam pontos frágeis que, se explorados por agentes maliciosos ou mesmo por falhas acidentais, podem comprometer diretamente a confidencialidade, a integridade e a

disponibilidade das informações. A análise dessas vulnerabilidades requer o uso combinado de ferramentas especializadas, mapeamento dos ativos e participação ativa de profissionais capacitados.

Também abordamos metodologias qualitativas e quantitativas de avaliação de riscos, ressaltando a importância de classificá-los conforme o seu impacto e a probabilidade de ocorrência. Esse processo facilita a priorização de ações e a tomada de decisões estratégicas, contribuindo para uma gestão de riscos mais eficaz.

Por fim, reforçamos o papel das políticas organizacionais de gestão de riscos como pilares normativos e orientadores. Elas devem ser realistas, atualizadas e comunicadas com clareza, promovendo uma cultura interna de prevenção e resposta responsável aos incidentes.

Diante de um cenário digital dinâmico e desafiador, espera-se que, ao final deste capítulo, o leitor esteja apto a olhar criticamente para o ambiente tecnológico da sua organização. Reconhecer que os riscos são inerentes à atividade organizacional e, portanto, devem ser gerenciados de forma estratégica e inteligente estabelece um cenário favorável para a adoção de práticas que fortaleçam a segurança da informação e protejam o negócio contra perdas evitáveis.

Referências

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS (ABNT). **ABNT NBR ISO/IEC 27005:2022**: tecnologia da informação: técnicas de segurança: gestão de riscos de segurança da informação. 3. ed. Rio de Janeiro: ABNT, 2022.

BARRETO, J. S.; ZANIN, A.; MORAIS, I. S.; VETTORAZZO, A. S. **Fundamentos de segurança da informação**. Porto Alegre: Sagah, 2018.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). **Diário Oficial da União**: seção 1, Brasília, DF, ano 156, n. 157, p. 59-64, 15 ago. 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 14 ago. 2025.

KONOPCZYK, M. G. **Riscos, auditoria e resposta a incidentes**. São Paulo: Editora Senac São Paulo, 2022.

LIMA, G. P. **Gestão de projetos**: como estruturar logicamente as ações futuras. Rio de Janeiro: LTC, 2009.

MACHADO, F. N. R. **Segurança da informação**: princípios e controle de ameaças. São Paulo: Érica, 2014.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **Guide for Conducting Risk Assessments (NIST Special Publication 800-30 Revision 1)**. Gaithersburg: NIST, 2012. Disponível em: <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>. Acesso em: 14 ago. 2025.

PEGETTI, A. **Gestão da segurança da informação**. São Paulo: Editora Senac São Paulo, 2022.

